

4. Protecting Secret → Encryption → Cryptography

Key { Symmetric key
Asymmetric key
Encipherment { Block Cipher
Stream Cipher

→ Access Control { MAC: Mandatory สิทธิการกำหนดโดย System Top secret, Secret, Confidential, Unclassified
DAC: Discretionary สิทธิการกำหนดโดย เจ้าของข้อมูล Ex. ACL, Read/Write/Execute | Windows, Linux
RBAC: Role base สิทธิการกำหนดโดย Role Ex. Role Admin, Staff, Manager
Rule Based AC: Rule base ใช้ Conditions ในการอนุญาตการเข้าถึง Ex. เวลา, IP, Location | Firewall, Network Security Login 08:00-18:00

} Subject
Object
Right

→ Obsecuring { Stegano : ซ่อน Secret ให้คนอื่นไม่ Secret
Anonymization : ซ่อน, Privacy / Sensitive info
Pseudo

5. Cyber Attack

Quiz 4:

Unauthorized Disclosure (รั่ว)
Deception (หลอกลวง)
Disruption (ขัดข้อง)
Usurpation (ขโมย)

Threats (ภัย) — Threat
Vulnerability Consequence

$$\text{Risk} = \text{Prob.} \times \text{Impact}$$

✔️ สรุปตาราง Threat Consequences (RFC 2828)			
กลุ่ม Threat Consequence	ลักษณะเฉพาะ	ผลกระทบต่อ Security	ตัวอย่าง Threat Actions
Unauthorized Disclosure	เปิดเผยข้อมูลลับ	Confidentiality	Exposure, Interception, Inference, Intrusion
Deception spoofing	หลอกลวง/ข้อมูลปลอม	Integrity, Authenticity	Masquerade, Falsification, Repudiation
Disruption	รบกวน/หยุดชะงักการทำงาน	Availability	Incapacitation, Corruption, Obstruction
Usurpation Elevation of Privilege	ยึดสิทธิ์/เข้าควบคุมระบบ	Integrity + Availability	Misappropriation, Misuse

Risk Management { 1. Risk Assessment → Risk Analysis
2. Risk Treatment

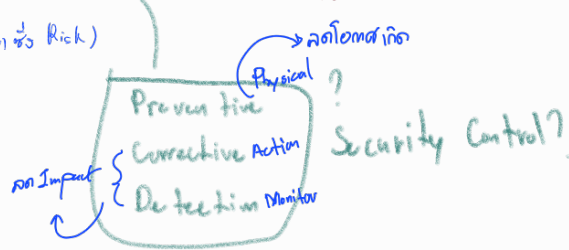
Qualitative Risk Analysis
Risk = Prob. x Impact

Quantitative Risk Analysis
ALE = SLE x ARO

Recovery Cost ก็คือ
Income Loss คุ้มหรือไม่? A?, %
- difficulty อนุกรมวิธาน 12/11/20
Cross benefit analysis
ER??
↳ business income

Risk Acceptance cost control > Audit impact Risk score 0-100
Risk Mitigation Reduction { ลด Prob. (Likelihood)
or Impact (Consequence)
Risk Avoidance (งด Activity ที่ก่อให้เกิด Risk)
Risk Transfer ย้ายความเสี่ยง
- อนุกรมวิธาน
- Cloud

Reflection



2) 100% 100% 100% 100% → prevent, Detective, Responce and Recovery

- 3 Control type
- Administrative Controls
 - Technical Controls
 - Physical Controls

Function Security Control

- 1. Preventive
- 2. Deterrent
- 3. Detective
- 4. Corretive
- 5. Recovery
- 6. Comprehensive

Means of Authentication

- 1. Something you know
- 2. possesses (token) have
- 3. static biometrics are
- 4. dynamic do

Hacker always Breck the Authentication then → Back door? Root hit?

Password Cracking

- 1. Dictionary attack
- 2. Rainbow table attack
- 3. Password easily guessable
- 4. John the Ripper
- Brute-Force Attack

- Wanna Cry → ransomware เฟอร์ไดโล
- zero day บั๊กใหม่ที่ยังไม่มีใครพบ
- DDOS การโจมตี server ทำให้ระบบล่ม
- Bluejacking ส่งข้อความ Bluetooth โทรศัพท์มือถือ
- Network sniffing การดักจับข้อมูลในเครือข่าย
- Shoulder surfing แอบมองจอคนอื่น
- MitM ดักจับข้อมูลบน wifi
- Kerberos

PKI → ระบบที่ประกอบด้วย Public key + Certificate ⇒ CA (Certificate Authority)

Attack Vector คือ

1.1 Common Threats

• Types of Cyber Threats

- Software Attack Ex. Dos, buffer overflow
- Software Error Ex. Logic Error
- Sabotage
- Human Error
- Theft
- Hardware Failures
- Utility Interruption
- Natural Disasters

• Threats to the Local Area Network LAN

• Threats to the Private Cloud

• Threats to the Public Cloud Ex. SaaS, PaaS, IaaS

• Threats to Applications Ex. Data loss, Server Downtime

• Threat Complexity Ex. Programming mistakes, Protocol Vulnerabilities, System Misconfiguration

- APT: Advanced persistent threat → ไม่จบไม่สิ้นโจมตีเรื่อยๆ จนกว่าจะเสร็จ
- Algorithm attack → ศึกษาและวิเคราะห์ algorithm
 - ↳ Ex. hash Algorithm → hash password แต่ input ไม่เหมือนกัน

• Backdoors and Rootkits — Malware

↳ by pass Authentication

Backdoor เชื่อมต่อรับ 1111111111111111 Malware Ex. RATs คอมพิวเตอร์โดน

Rootkit แทรกซ้อนบนตัวโปรแกรมปฏิบัติการ Ex. zombie / botnet

• Threat Intelligence and Research Sources

IOC หรือร่องรอยที่แจ้งเตือนภัย

✔ เปรียบเทียบ Backdoor vs Rootkit

คุณสมบัติ	Backdoor	Rootkit
จุดประสงค์	เปิดทางเข้าให้โจมตีระบบ	ซ่อนมัลแวร์และควบคุมระบบ
การเข้าถึง	ข้าม authentication, ให้ remote access	ยกระดับสิทธิ์ (Privilege escalation), ควบคุม OS
การตรวจจับ	ค่อนข้างง่ายกว่าหากมีการ monitor network	ยากมากเพราะ rootkit ซ่อนตัวใน OS
ผลกระทบ	ทำให้ผู้โจมตีเข้ามาได้เรื่อยๆ	ทำให้ผู้โจมตีควบคุมได้แบบลึก (kernel level)

1.2 Deception

• Social Engineering Tactics 7

1. Authority ช้างบ้านเฉย → เชื้อขันธ์ ไม่ค่อยติดตัว
2. Intimidation อยุ่ขู่ → รับทำของ
3. Consensus ล้างรถรถตามร้านสะดวกซื้อ → ยอมทำตามทุกคนทำ
4. Scarcity ทำให้รู้สึกว่าของหายาก/มีจำกัด → ทำได้เร็วทันใจ เมื่อไม่มาซื้อโอกาส
5. Urgency เร่งด่วน → ชวนซื้อให้เร็วขึ้นใจ ไม่ทันคิดอะไร
6. Familiarity ความคุ้นเคย → ถ้ามั่นใจในคนรู้จัก
7. Trust ได้รับความไว้วางใจ → ลิงๆ เขาทำเรื่องแบบนี้ได้ น่าเชื่อถือด้วย

• Shoulder Surfing and Dumpster Diving

↳ มองบิ๊นในลิ้น → ดูเอกสาร

↳ ดูถังขยะ: → ดูเอกสาร

• Impersonation and Hoaxes

↳ การสวมรอย / แล้วยังทำงาน
↳ แลกรับเงินเมื่อทำสิ่งที่ผิดๆ ไม่ทำ

↳ ฉ้อโกง / การหลอกลวง
↳ ขโมยข้อมูลคนอื่น ใช้ในสิ่งที่ได้จริง / ขโมย

• Piggybacking and Tailgating

↳ ยืนรอให้เปิดประตู
เมื่อคนออกในเคาน์เตอร์พนักงานปิด

↳ ตามคนเข้าไปในตึกที่เขารู้จัก

• Other Methods of Deception

✓ สรุปให้เข้าใจง่าย

- Invoice Scam → ใบแจ้งหนี้ปลอม หลอกให้จ่ายเงิน
- Watering Hole → เจาะเว็บที่เป้าหมายใช้บ่อย → ติดมัลแวร์
- Typosquatting → สร้างเว็บชื่อคล้าย → หลอกให้เข้าเว็บปลอม
- Prepending → ใส่ข้อความหลอกใน email/URL → เพิ่มความน่าเชื่อถือ
- Influence Campaigns → ใช้ข่าวปลอม/โซเชียลมีเดีย → บั่นความเห็นสาธารณะ

1.3 Cyber Attacks

- What's the Difference?

virus ไวรัส
worms ไ้พ้องพาหะ
Trojan horse เสน่ห์ม้าโทรจัน

- Logic Bombs Code ปลูกไว้เพื่อจุดประสงค์ → ทำลาย/ลบ/ทำลายข้อมูล → Antivirus, IDS/IPS, Code Review

- Ransomware → 勒索软件 → 勒索软件 Threat AES, RSA Ex.

Phishing Email → 钓鱼邮件 .docm .exe .zip
Malicious Link → 恶意链接
Exploit kits → 漏洞利用工具
RDP → Remote Desktop Protocol
Remote Desktop Protocol

- Denial of Service Attacks

- Domain Name System

- Layer 2 Attacks

- Man in the Middle and Man in the Mobile Attacks

- Zero-Day Attacks

- Keyboard Logging

- Defending Against Attacks

Buffer Overflow 缓冲区溢出攻击

1. Unauthorized Disclosure (การเปิดเผยข้อมูลโดยไม่ได้รับอนุญาต)

- **ความหมาย:** กรณีที่ผู้ไม่ได้รับสิทธิ์เข้าถึงข้อมูลที่เป็นความลับ
- **Threat Actions:**
 - **Exposure:** ข้อมูลถูกเปิดเผยตรง ๆ ให้กับบุคคลที่ไม่ได้รับสิทธิ์
 - **Interception:** ดักจับข้อมูลระหว่างทาง เช่น sniffing network
 - **Inference:** ใช้การ suy luận หรือ pattern analysis เพื่อสรุปหาข้อมูลที่เป็นความลับ แม้ไม่ได้เห็นข้อมูลดิบทั้งหมด
 - **Intrusion:** ฝ่าระบบรักษาความปลอดภัยเพื่อเข้าถึงข้อมูล

2. Deception (การหลอกลวง / ข้อมูลปลอม)

- **ความหมาย:** กรณีที่ entity ที่มีสิทธิ์ได้รับข้อมูลปลอม และเข้าใจผิดว่าข้อมูลนั้นจริง
- **Threat Actions:**
 - **Masquerade:** ผู้โจมตีปลอมตัวเป็น entity ที่ถูกต้อง เช่น spoofing, phishing
 - **Falsification:** ส่งข้อมูลเท็จเพื่อหลอกเหยื่อ เช่น ปลอม log file, ปลอม transaction
 - **Repudiation:** การปฏิเสธความรับผิดชอบ เช่น ผู้ใช้ปฏิเสธว่าไม่ได้ทำธุรกรรม ทั้งที่แท้จริง

3. Disruption (การรบกวน / ขัดจังหวะการทำงาน)

- **ความหมาย:** การโจมตีที่ทำให้ระบบทำงานผิดปกติหรือหยุดชะงัก
- **Threat Actions:**
 - **Incapacitation:** ปิดการทำงานหรือ disable system component เช่น DoS/DDoS
 - **Corruption:** แก้ไขข้อมูล/ฟังก์ชันของระบบให้ทำงานผิด เช่น แก้ไข DB records
 - **Obstruction:** กีดขวางการให้บริการ เช่น ทำให้ network overload, jam signal

4. Usurpation (การยึดครอง / เข้ายึดระบบโดยไม่ได้รับอนุญาต)

- **ความหมาย:** การที่ผู้ไม่ได้รับอนุญาตเข้ามาควบคุมระบบหรือ service
- **Threat Actions:**
 - **Misappropriation:** ยึดสิทธิ์ logical/physical control ของ resource เช่น hijacking session
 - **Misuse:** ใช้ resource/system ให้ทำงานในสิ่งที่เป็นอันตราย เช่น ใช้ server ส่ง spam, ใช้ IoT botnet โจมตี DDoS

1.CIA Triad ซึ่งเป็นส่วนหนึ่งของ Basic Security Principles มีด้านใดบ้าง จงอธิบาย

1. Confidentiality ปกป้องข้อมูลลับ ใช้ Access Control, Encryption

2. Integrity ข้อมูลถูกต้อง ครบถ้วน ใช้ Hash, Digital Signature

3. Availability ข้อมูลพร้อมใช้งาน ใช้ Backup, Redundancy, ป้องกัน DoS

2.นอกเหนือจาก CIA Triad แล้ว Security Principle มีด้านใดอีกบ้าง จงอธิบาย

Authenticity ข้อมูล/ผู้ใช้งานแท้จริง

Accountability ตรวจสอบย้อนกลับได้ (Audit, Log)

Reliability ระบบมีเสถียรภาพ

Non-repudiation ผู้ส่งไม่สามารถปฏิเสธการกระทำได้ (Digital Signature)

3.Data มีกี่ states อะไรบ้าง พร้อมยกตัวอย่าง Threats ที่มีผลกระทบต่อ Data แต่ละ State

Data In Transit: กำลังส่ง ยกตัวอย่าง Threats Sniffing, MITM

Data At Rest: ถูกเก็บ ยกตัวอย่าง Threats Unauthorized Access, Ransomware

Data In Use: กำลังประมวลผล ยกตัวอย่าง Threats Memory Scraping, Keylogger

4.Threats สามารถถูกจัดเป็นกลุ่มตามคำนิยาม Threat Consequence ใน RFC 2828 ได้กี่กลุ่ม แต่ละกลุ่มมีลักษณะเฉพาะอย่างไร

1. Unauthorized Disclosure รั่วไหลข้อมูล (Confidentiality)

2. Deception หลอกหลวง ปลอมแปลง (Integrity, Authenticity)

3. Disruption หยุดชะงัก (Availability)

4. Usurpation ยึดครอง/ใช้สิทธิ์โดยมิชอบ (Control, Integrity)

5. จงอธิบายบทบาทของ Security Controls หรือ Countermeasure ที่มีต่อ Asset ในบริบทเรื่อง Cybersecurity

ปกป้อง Asset จาก Threat

ลดช่องโหว่ (Mitigate Vulnerabilities)

ลดผลกระทบ (Impact) ด้วย Backup/DR

สร้าง Accountability ด้วย Logging/Monitoring

6. Security Controls สามารถแบ่งกลุ่มได้กี่กลุ่ม อะไรบ้าง จงอธิบายลักษณะเฉพาะของแต่ละกลุ่ม

Management → นโยบาย, Risk Assessment, Training

Operational → Incident Response, DR/BCP, Physical Security

Technical → Firewall, Encryption, IDS/IPS, Access Control

7. ก่อนที่จะตัดสินใจเลือก Security Control มาใช้งาน ต้องทำสิ่งใดก่อนและใช้เงื่อนไขใดในการตัดสินใจเลือก

ทำ Risk Assessment Identify Asset > Threat > Vulnerability > Risk

เงื่อนไขการเลือก: ระดับความเสี่ยง, ความสำคัญของ Asset, Cost Benefit, Compliance, ความเหมาะสมขององค์กร

8. Risk Treatments คืออะไร มีกี่รูปแบบ แต่ละรูปแบบเกี่ยวข้องกับอะไรกับการเลือก Security Controls

1. Avoidance: ขกเลิกกิจกรรมเสี่ยง อาจไม่ต้องใช้ Controls

2. Reduction: ใช้ Controls เพื่อลดโอกาส/ผลกระทบ Firewall, Encryption

3. Transfer: โอนให้บุคคลที่สาม Cyber Insurance, Cloud Provider

4. Acceptance: ยอมรับความเสี่ยง ใช้ minimal control หรือ monitoring

9.จงอธิบายคำจำกัดความของคำต่อไปนี้

1. Attack Vector ช่องทาง/วิธีที่โจมตีเข้ามา (เช่น Phishing, Malware)
2. Attack Surface ช่องโหว่ทั้งหมดที่ผู้โจมตีเข้าถึงได้ (Network, Software, Human)
3. IOC หลักฐานบ่งบอกการโจมตี เช่น Malware Hash, Suspicious IP

10.Pillar หลักทั้ง 3 ที่สำคัญของ Security controls หรือ Countermeasure หรือ Safeguards มีอะไรบ้าง และจงอธิบายลักษณะเฉพาะของแต่ละ Pillar

Preventive: ป้องกันตั้งแต่ต้น เช่น Firewall, MFA, Training

Detective: ตรวจจับเมื่อเกิดเหตุ เช่น IDS, Log, SIEM

Corrective/Recovery: แก้ไข/กู้คืน เช่น Backup, DRP, Patch

11.จงอธิบายความแตกต่างระหว่าง Qualitative Risk Analysis และ Quantitative Risk Analysis โดยเลือกใช้ไฟล์ที่เคยให้ไป

Qualitative: ใช้การจัดลำดับ (High/Med/Low) → ทำง่าย เร็ว แต่ไม่เป็นตัวเลข

Quantitative: ใช้ตัวเลข เช่น ALE, SLE → ชัดเจนด้านการเงิน แต่ซับซ้อน ใช้เวลามาก

12.จงอธิบายว่าอะไรคือขั้นตอนต่อไปในการทำ Risk Management หลังการทำ Risk Assessment โดยมีทางเลือกอะไรบ้าง และมีเงื่อนไขในการเลือกอย่างไร

ทำ Risk Treatment (4 ทางเลือก: Avoid, Reduce, Transfer, Accept)

เงื่อนไข: ระดับความเสี่ยง, มูลค่า Asset, Cost-Benefit, Compliance

13.จงอธิบายความสัมพันธ์ระหว่างทางเลือกในการทำ Risk Management ในคำถาม "จงอธิบายว่าอะไรคือขั้นตอนต่อไปในการทำ Risk Management หลังการทำ Risk Assessment โดยมีทางเลือกอะไรบ้าง และมีเงื่อนไขในการเลือกอย่างไร" กับกลุ่ม Security Control

Avoidance > Management Control (Policy)

Reduction > Technical + Operational Controls (Firewall, IDS, DRP)

Transfer > Management Controls (Insurance, SLA)

Acceptance > Minimal Controls (Monitoring, Documentation)

Lab1 AES Encryption

AES Encryption	AES Decryption
Enter Plain Text to Encrypt Hiw	AES Encrypted Text a02Tj4ep3Bx0Bi9hAZ1wxA==
Select Cipher Mode of Encryption CBC	Select Cipher Mode of Decryption CBC
Select Padding NoPadding	Select Padding NoPadding
Enter IV (Optional) Enter initialization vector	Enter IV Used During Encryption(Optional) Enter initialization vector
Key Size in Bits 128	Key Size in Bits 128
Enter Secret Key TlNnPP1234567890	Enter Secret Key used for Encryption SECRETKEY16tour!
Output Text Format ☒ Base64 ☐ Hex	Output Text Format ☒ Plain-Text ☐ Base64
Encrypt	Decrypt
AES Encrypted Output snHpzdQxndsSQeW9u/mjng==	AES Decrypted Output Hello world????!!

Encryption

1. กำหนด Secret Key เพื่อแชร์กับเพื่อน
2. นำ Plaintext ไป Encrypt ด้วย Secret key ของผู้ส่ง (Secret key ที่ทั้ง 2 ฝ่ายรู้)
3. Cipher Mode เลือก CBC
4. IV ใส่ก็ได้ ไม่ใส่ก็ได้
5. Key size >> 128 bits
6. นำ Ciphertext ที่ได้ส่งให้เพื่อน

Decryption

1. นำ Ciphertext มา Decrypt ด้วย Secret key ที่ตกลงกันกับเพื่อน
2. Cipher Mode เลือก CBC
3. IV ใส่ก็ได้ ไม่ใส่ก็ได้
4. Key size >> 128 Bits
5. จะได้ Plain text ออกมา

Lab2 RSA Encryption

Generate RSA Key Pair Online

Select RSA Key Size ⓘ

1024 bit

Generate RSA Key Pair

Public Key(X.509 Format)

-----BEGIN PUBLIC KEY-----
MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQDPLqUiamWrSQpexsCe1nG/BUHTPs7obB7sbqJlx+FLiUjOw
U7zVeqITq8ysJgTYH7KQ7jDmKSx8lZPbD2Jj9sblVX7+uXi6pyQ0vtzG7j8nR7ailLWwQLsfX4LJMgYtqNpD01mZ9c
RaajBUAtyJednkDAVycEQGd7wqN9COHUEQIDAQAB
-----END PUBLIC KEY-----

Download Public Key

Private Key(PKCS8 Format)

-----BEGIN RSA PRIVATE KEY-----
MIICDglBADA...
-----END RSA PRIVATE KEY-----

Download Private Key

1. Generate Key pair ด้วย Key size 1024 bit

RSA Encryption

Enter Plain Text to Encrypt ⓘ

หน้า ๑

Enter Public/Private key ⓘ

-----BEGIN PUBLIC KEY-----
MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQCBPX/aSWZFEPpSWWLLJ5WxO2nYqw+cXEe1qIPQA2jZ8J
Is+UfhcGjOgEiFthWluYu8hea0oJNLla2BICl0dDbHDkbugXdk9jef44kHb4oT4Vj7SSxBzTQclQrlzO17emfWIIAoyU
JrqXOoGsSNrkFuXZ8nuLf24zTbwKntlyVQIDAQAB
-----END PUBLIC KEY-----

RSA Key Type: ⓘ ☒ Public key ☐ Private Key

Select Encryption Algorithm ⓘ

RSA

Encrypt

Encrypted Output (Base64):
MvNggGbvwpNwhgYSW9xZcoNwEY2pg9bFvaZCsHsZGZlqPjIPV+2MfYy+vaOqBL+YQJlUOJ3vnJCR9YEIsKl67Q
s446Y2nxtJYZLwOgB8GASQ/4JwnoFkP45pREt/MVvm5fkmTjDFYjF2/EFrO1lLe6j1g3leOeLYcYp54Os=

RSA Decryption

Enter Encrypted Text to Decrypt (Base64) ⓘ

Q5w8qBNmHRWwF0xzkK6j7M6rTEuAugtZWzmDkTqJnM8WqvPgF/KWkP63dLpsAlaw+CbzIfs19pRcl7BQ9+Df
bJeyvXdhOlf5YcSXKjnc76vHVS5N8sQ1w6EY8hxbZgh8ugng30bSkcWtdBF1OZeHfJlTP07BvqaWAONccklr8VU=

Enter Public/Private key ⓘ

d300amqD8b3dr7mBwsP2puI+WNi1UqdFmIMYksp5z7d2Mu+Lx4q9la74cqHnelq0hnXaUbQJOIMCQCQCq
GQSIUI9LjQndHydrOPPKVxXJvoRYGc9PjJ/jcs1dtQfR44OhfXONC2/9q5HD6Nrk110r8sCW+FpsFseGCpAkAo
KIHkgPUey1jorxJW3CISgrPUrAjY7ZVxHRL72lSRqv3pvsPTrGZk3d5TSdZpitBQmilzlyApxwbid9mHD13lAkEAl
Uoo9XSFZ6a6y4Y/kzs54/Fhca4vDbVYrzdRXMSYVE1C3J00dPp29+TjJhLCKC4Yj41S9FnGZGzd1Jn2lJjuQJ
BAIBGBAQccStf4zkWyMcX4NilFkG5xutAPd/vT566urkMlturNNIG0KbDKZAYVzbd7SjFPlslxWdS7c8Prao/gc
=

RSA Key Type: ⓘ ☐ Public key ☒ Private Key

Select Decryption Algorithm ⓘ

RSA

Decrypt

Decrypted Output:
ข่าวฉลกรเพราะทรอบ+โศดาว พิเศษ

Encryption

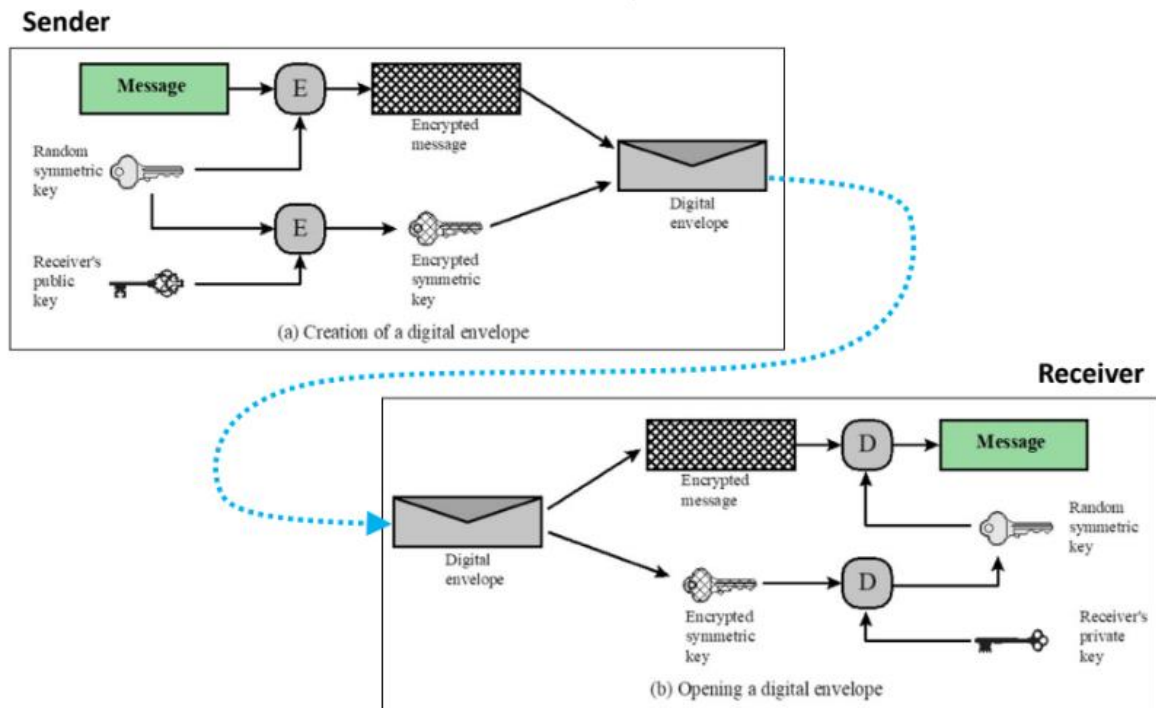
- นำ Plain text มา Encrypt ด้วย Public key ของเพื่อน
- Algorithm เลือก RSA
- นำ Cyphertext ส่งให้เพื่อน

Decryption

- นำ Cyphertext มา Decrypt ด้วย Private key ของตัวเอง
- Algorithm เลือก RSA

Lab3 Digital Envelope

System Components



Encrypt 2 ชั้น โดยใช้ AES และ RSA

Encrypt ชั้นที่1 ด้วย AES

1. นำ Plaintext มา Encrypt ด้วย AES + CBC + No padding + IV + Symmetric key

Encrypt ชั้นที่2 ด้วย RSA

1. นำ Symmetric key มา Encrypt ด้วย RSA + 1024 bit + Public key(ผู้รับ)

Decrypt 2 ชั้น โดยใช้ RSA และ AES

Decrypt ชั้นที่1 ด้วย RSA

1. นำ Encrypted symmetric key มา Decrypt ด้วย RSA + Private key(ผู้รับ)

Decrypt ชั้นที่2 ด้วย AES

1. นำ Cipher text มา Decrypt ด้วย symmetric key ที่ได้มาจากการ Decrypt ด้วย RSA

AES Encryption

Enter Plain Text to Encrypt

as'ls 1

Select Cipher Mode of Encryption 2

CBC

Select Padding 3

NoPadding

Enter IV (Optional) 4

Enter initialization vector

Key Size in Bits 5

128

Enter Secret Key 6

1234567890123456

Output Text Format ☒ Base64 ☐ Hex

Encrypt 7

AES Encrypted Output

dNu2J78RLPo+JrrxVhGfvA== 8

Select RSA Key Size 9

1024 bit

Generate RSA Key Pair

Public Key(X.509 Format)

-----BEGIN PUBLIC KEY-----

MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQCG2Avpj+DQBffozgwkQSMr2INpAeAkTrvXHTNBpfdZv49ghrodYAyDd0GUONCXx6Rx4UzRnlSgK6y20fKoq8Bhp6EtrRfKyuuJwsIX1g7hi42MIFZLgezVx9xhmJgD5dluHtoSKgMREs5FYewQJoaEPNxN3QDZLvD0VXXbq5MwIDAQAB

-----END PUBLIC KEY-----

Download Public Key

AES Decryption

AES Encrypted Text

dNu2J78RLPo+JrrxVhGfvA== 5

Select Cipher Mode of Decryption 6

CBC

Select Padding 7

NoPadding

Enter IV Used During Encryption(Optional) 8

Enter initialization vector

Key Size in Bits 9

128

Enter Secret Key used for Encryption 10

1234567890123456

Output Text Format ☒ Plain-Text ☐ Base64

Decrypt ?

AES Decrypted Output

as'ls 11

Private Key(PKCS8 Format)

-----BEGIN RSA PRIVATE KEY-----

MIICdwIBADANBgkqhkiG9w0BAQEFAASCAmEwgGJdAgEAAoGBAKDYC+mP4NAF9+JODCRBlyal2k84CRou9cdM0G9I9m/2C0Uhl1gDUJPQZ40JfHhTNGeVKArLbR8qirwG8noS2tF8K64nCyVfWKDuEjYyVvkuB7NXH3GGYmAPI0I4e2h1qAxESzkVh7BAmhP48/E3dANKutV3RVddurkzAgMBAAECgYALh+bgDqgvaoM9NbsEb7Bazh+oa9xVc1jFZMDY8vysRxcSP3Zg8Wgra6g9kmPPOHfJ6jynRnl2ARy2FmUowd61Ga5vok0HTWvGpQUapTjcJ+Gt5Kjjs/LQodG96nj3mCNrTKemA1UNqLdbg3rPjZBt0kkVIX65V5n++cwBz92IYQJBALsqrYvaT1Ce

Download Private Key

RSA Encryption and Decryption

Below is the form to take the inputs for the encryption and decryption. By default, the public/private keys are prepopulated with the keys generated above. You can also supply your own public/private key pairs.

RSA Encryption

Enter Plain Text to Encrypt 10

1234567890123456

Enter Public/Private key 11

-----BEGIN PUBLIC KEY-----

MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQCG2Avpj+DQBffozgwkQSMr2INpAeAkTrvXHTNBpfdZv49ghrodYAyDd0GUONCXx6Rx4UzRnlSgK6y20fKoq8Bhp6EtrRfKyuuJwsIX1g7hi42MIFZLgezVx9xhmJgD5dluHtoSKgMREs5FYewQJoaEPNxN3QDZLvD0VXXbq5MwIDAQAB

-----END PUBLIC KEY-----

RSA Key Type: ☒ Public key ☐ Private Key

Select Encryption Algorithm 11

RSA

Encrypt

Encrypted Output (Base64):

jDu4Yvlt/Zv76D6aW4ca2eSmB5+UstJ8f78edofu2U+IDVpgcJfIfAqWPFKIdJlre8eY8GVAA84JahWzN6ezQ3IBOVXq9FqIR0YkUxuLkRX11hb2a86pXhGf/MCrA6Z8jDI0ei+zQjJNWpcymwRADiDhoP4/SOIAXuEL7sMHE4= 12

RSA Decryption

Enter Encrypted Text to Decrypt (Base64) 1

jDu4Yvlt/Zv76D6aW4ca2eSmB5+UstJ8f78edofu2U+IDVpgcJfIfAqWPFKIdJlre8eY8GVAA84JahWzN6ezQ3IBOVXq9FqIR0YkUxuLkRX11hb2a86pXhGf/MCrA6Z8jDI0ei+zQjJNWpcymwRADiDhoP4/SOIAXuEL7sMHE4=

Enter Public/Private key 2

-----BEGIN RSA PRIVATE KEY-----
MIICdwIBADANBgkqhkiG9w0BAQEFAASCAmEwgGJdAgEAAoGBAKDYC+mP4NAF9+JODCRBlyal2k84CRou9cdM0G9I9m/2C0Uhl1gDUJPQZ40JfHhTNGeVKArLbR8qirwG8noS2tF8K64nCyVfWKDuEjYyVvkuB7NXH3GGYmAPI0I4e2h1qAxESzkVh7BAmhP48/E3dANKutV3RVddurkzAgMBAAECgYALh+bgDqgvaoM9NbsEb7Bazh+oa9xVc1jFZMDY8vysRxcSP3Zg8Wgra6g9kmPPOHfJ6jynRnl2ARy2FmUowd61Ga5vok0HTWvGpQUapTjcJ+Gt5Kjjs/LQodG96nj3mCNrTKemA1UNqLdbg3rPjZBt0kkVIX65V5n++cwBz92IYQJBALsqrYvaT1Ce
-----END RSA PRIVATE KEY-----

RSA Key Type: ☐ Public key ☒ Private Key

Select Decryption Algorithm 3

RSA

Decrypt

Decrypted Output:

1234567890123456 4

หมวด	รายละเอียด	ตัวอย่าง
Threat Actors (ผู้โจมตี)	กลุ่มบุคคลที่มีแรงจูงใจและวิธีการต่างกัน	- Script Kiddies: มือใหม่ ใช้เครื่องมือสำเร็จรูป - Vulnerability Brokers: ค้นหาช่องโหว่แล้วขาย - Hacktivists: ใช้การแฮ็กประท้วงทางการเมือง/สังคม - Cybercriminals: อาชญากรไซเบอร์ หวังผลกำไร - State-sponsored Hackers: กลุ่มที่รัฐสนับสนุน ทำ Cyber Espionage
Attack Vectors (เส้นทางโจมตี)	ช่องทางหรือวิธีที่ Threat Actor ใช้เข้าถึงระบบ	- Phishing Email / Malicious Link - USB ติดมัลแวร์ - ช่องโหว่ซอฟต์แวร์ (Software Exploits) - Social Engineering - Weak/Leaked Passwords
Risk Strategies (การจัดการความเสี่ยง)	วิธีการตอบสนองเมื่อพบความเสี่ยง	- Accept: ยอมรับความเสี่ยงหากต้นทุนต่ำกว่าผลเสีย - Avoid: หลีกเลี่ยงกิจกรรมที่มีความเสี่ยง - Reduce (Mitigate): ลดความเสี่ยง เช่น ติด Firewall, Patch ระบบ - Transfer: โอนความเสี่ยง เช่น ซื้อประกันความปลอดภัยไซเบอร์
ผลกระทบของ Network Breaches	สิ่งที่เกิดขึ้นเมื่อระบบเครือข่ายถูกโจมตี	- E-commerce หยุดชะงัก - สูญเสียข้อมูลธุรกิจ - ข้อมูลส่วนบุคคลรั่วไหล (Privacy Threat) - Integrity ของข้อมูลถูกทำลาย
การป้องกัน (Mitigation)	การใช้เครื่องมือและความร่วมมือ	- Cisco Talos Intelligence, PSIRT - แชรข้อมูล IOC (Indicators of Compromise) - Cybersecurity Awareness Training - หน่วยงาน: CISA, NCSA

Critical Information Infrastructure: CII



<https://www.thaicert.or.th/en/cii/>

Final

Quiz (Malware & Attack) (~ 9.45 น)

- 1.) การแพร่กระจายและโจมตี (Action on Objectives) แบ่งได้เป็นกี่แนว อะไรบ้าง.
- 2.) Morris Malware มีรูปแบบการแพร่กระจายและโจมตี อย่างไร
และ DDoS Attack มีลักษณะอย่างไร
- 3.) DoS Attack¹ มีรูปแบบการโจมตี 2 แนวใหญ่ ๆ อะไรบ้าง
และ ยกตัวอย่าง การโจมตีในทิศทางใด 1 ตัวอย่าง
- 4.) จงอธิบาย ขั้นตอนการป้องกัน (Countermeasure) การโจมตีที่สอดคล้อง ตามมาตรฐาน NIST framework

Nist Frame

Preparation →

Final * Lockheed Martin

Cyber kill Chain → 6 ขั้นตอนการบุกรุกคอมพิวเตอร์

ถ้ายังไม่ถึง phase 9 ได้ → Hacker จะใช้ความสามารถที่หาได้เพื่อป้องกันการโจมตีได้

1. Reconnaissance ^{สอดแนม}  Active → Need สามารถเข้าถึงระบบแล้วสามารถทำอะไรก็ได้
Passive → No need สอดแนมแบบไม่ใช้ระบบ Internet Ex. port ของระบบ IP

2. Weaponization ^{อาวุธ} Ex. Malware

98 Tools ต่างๆ

Phishing

Vulnerable Application or Servers

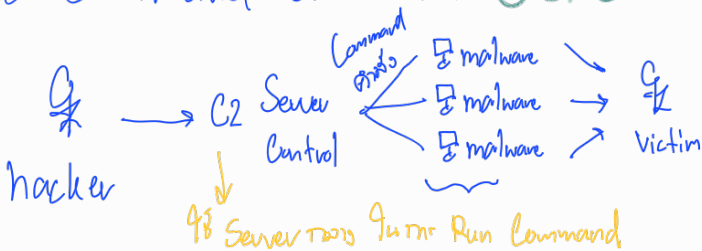
Insider Threats

3. Delivery ^{การส่งมอบ} → การส่งมัลแวร์ให้เหยื่อ Ex.  Email Attachments
• malicious link (Link อันตราย)
• USB drive
Code ในไฟล์จะ Run

4. Exploitation ^{การโจมตีระบบ} → การเข้าระบบแล้ว

5. Installation → ติดตั้ง Backdoor บนที่ที่เราเข้าถึงได้เพื่อรอวันขึ้น

6. Command & Control C&C → C2 Server

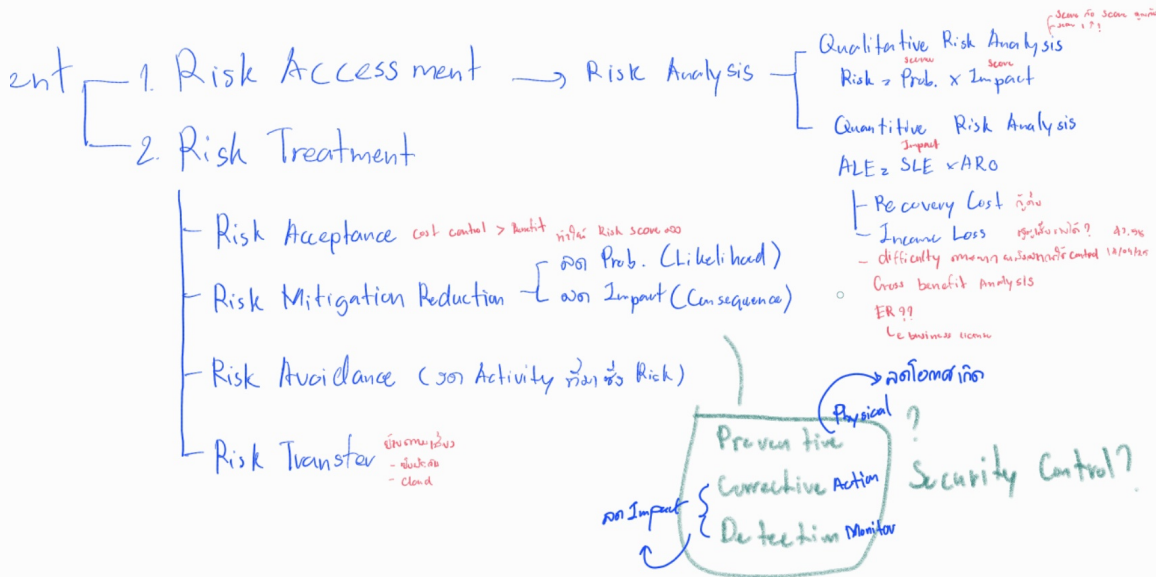


7. Actions and Objective Hacker จะทำอะไร
↳ ทำตามวัตถุประสงค์

การคูณตัว CIA

- 6 ตัวอย่างการ
1 ไม่มีการป้องกัน → Digital signature
A ไม่มีการป้องกัน Password, เติบโตตาม

1. Describe risk assessment and treatment including practical security improvement solution for the assigned asset.
2. IRP/DRP/BCP เป็น Security Control เพื่อป้องกัน Threat กลุ่มใด และ Security Principle ด้านใด
3. จงอธิบายเหตุผลในการเลือกระหว่าง Hot Site และ Warm Site
4. จงอธิบายเหตุผลในการกำหนด Backup Policy
5. อธิบายความแตกต่างระหว่าง Firewall แบบ Stateful และ ไม่ Stateful
6. Sinkhole คืออะไร



ใบส่ง Lab 4

Practice #4

Digital signature using SHA-256 and RSA encryption

06017467 Information and Cyber Security

16/08/2568

By Sumet Prabhavat, IT/KMITL

2.10.00

System Components

Sender: Bob

Receiver: Alice

Message M

Cryptographic hash function

Digital signature generation algorithm

Digital signature verification algorithm

Bob's private key

Alice's public key

Bob signs a message

Alice verifies the signature

Signature is valid or not valid

Practice #4 Digital Signature

- Access to the following lab-sheet link: https://docs.google.com/forms/d/1B6X889_1k3k8f8p0p1C0205977v0v4508111101Xv0ed8tgn4217775278pjd-4217775277
- Sender side
 - Generate message m → 1. write down m to the lab sheet
 - Generate keys
 - A pair of keys: public key and private key → 2. write down public key
 - Calculate hash of message m using SHA-256
 - Encrypt hash of message m to a ciphertext using RSA → 3. write down the signed hash of m
- Receiver side
 - Calculate hash of message m using SHA-256 → 4. write down the calculated hash of m
 - Decrypt the received encrypted hash using RSA → 5. write down the decrypted hash of m

Try using <https://www178.github.io/online-tools/sha256.html> or <https://www178.github.io/online-tools/sha256-hash-generator/>

Notes

Genali

Risk = Prob x Impact

ALE = ARO x SLE

Risk Treatment

Avoidance

Risk Mit

Risk Transfer

Risk Acceptance

2.

แผนเผชิญเหตุ, จินตนาการต่อหน้า

Incident 1, 2, ...

Action Plan 1, 2, ...

Cirp? กับแผนเผชิญเหตุ Ex. หอสมุดใหม่
+ ชั้นแผนเผชิญเหตุ

ไม่เสี่ยงอะไร มันระบบไม่เกิดเหตุ หรือผิดปกติ

Threat ที่เกิดจากคน

มีแผน?

- IRP → จัดการและตอบสนองเหตุการณ์ด้านความมั่นคงปลอดภัย
- DRP → กู้คืนระบบและข้อมูลหลังเกิดภัยพิบัติ (ตรงกับจริง)
- BCP → ทำให้ธุรกิจดำเนินต่อไปได้แม้ระบบหลักเสียหาย

Cyber due, Cyber Exercise

1. ทดสอบในใจ ในห้องจริง?
2. PR สำหรับสังคมภายนอก

Cycle IRP ??
? prepare

Detect

Identify

(ใช้ข้อมูล) Containment จำกัดวงเสียหาย

(Safe state) Eradication กำจัดต้นตอ

(Normal state) Recovery

Host? Accident lessen harm

Risk Assessment



วิธีแผน IRP, DRP, BCP

3. High Availability ทั้งห้องคอมพิวเตอร์ ทั้งตัวฮาร์ดแวร์ 1
Redundance Solution

Access N/10/20 ?

single point of failure → ถ้า RAID ทั่วไป Hardish ฮาร์ดแวร์ 1 → ทำให้ Available ↑

system factorant → ถ้า Server ฮาร์ดแวร์ 1

Switch

Board case frame

Band width

Spanning tree protocol (STP)

Forward error port ?

Redundance Gateway (FHRP)

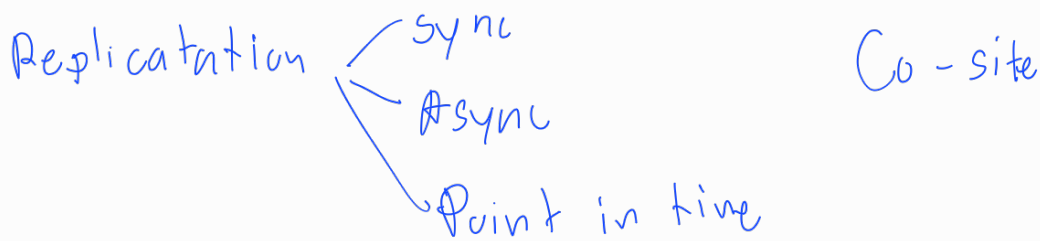
Virtual Router

HSRP Active Stand by

VRRP

GLBP Active Active

DR site → main/Primary Site



Key ส่วนประกอบของ Disrupt BIA ส่วนที่ Primary RTO

Recovery time Objective

MTD

MTPD

Recovery Disrupt

Recovery time

Condition → $RTO \ll MTD$

4. 1. วิธีการ Storage กับ Backup

- Local
- Oppsite

2. วิธีการ Backup

- Full (ทั้งหมด)
- Diff Diff กับ Full →
- Incremental Backup เก็บข้อมูลเพิ่ม

3. วิธีการสำรอง Backup

→ วิธีการสำรอง

→ RPO Recovery point

ข้อมูลสำรองที่เก็บไว้

Active → ข้อมูล Dynamic → RPO คืออะไร

ข้อมูล → ข้อมูล Dynamic → RPO คืออะไร → Backup คืออะไร

ข้อมูลสำรองที่เก็บไว้

ข้อมูลสำรอง

4. วิธีการสำรองข้อมูล RTO → วิธีการ MTD

↓
BIA
↓
RA

D. set fire wall / around ทั่วทั้งไฟไม่ไว้วางน

Inbound → ทั่วไปปกติที่ไว้วางนเอาไว้

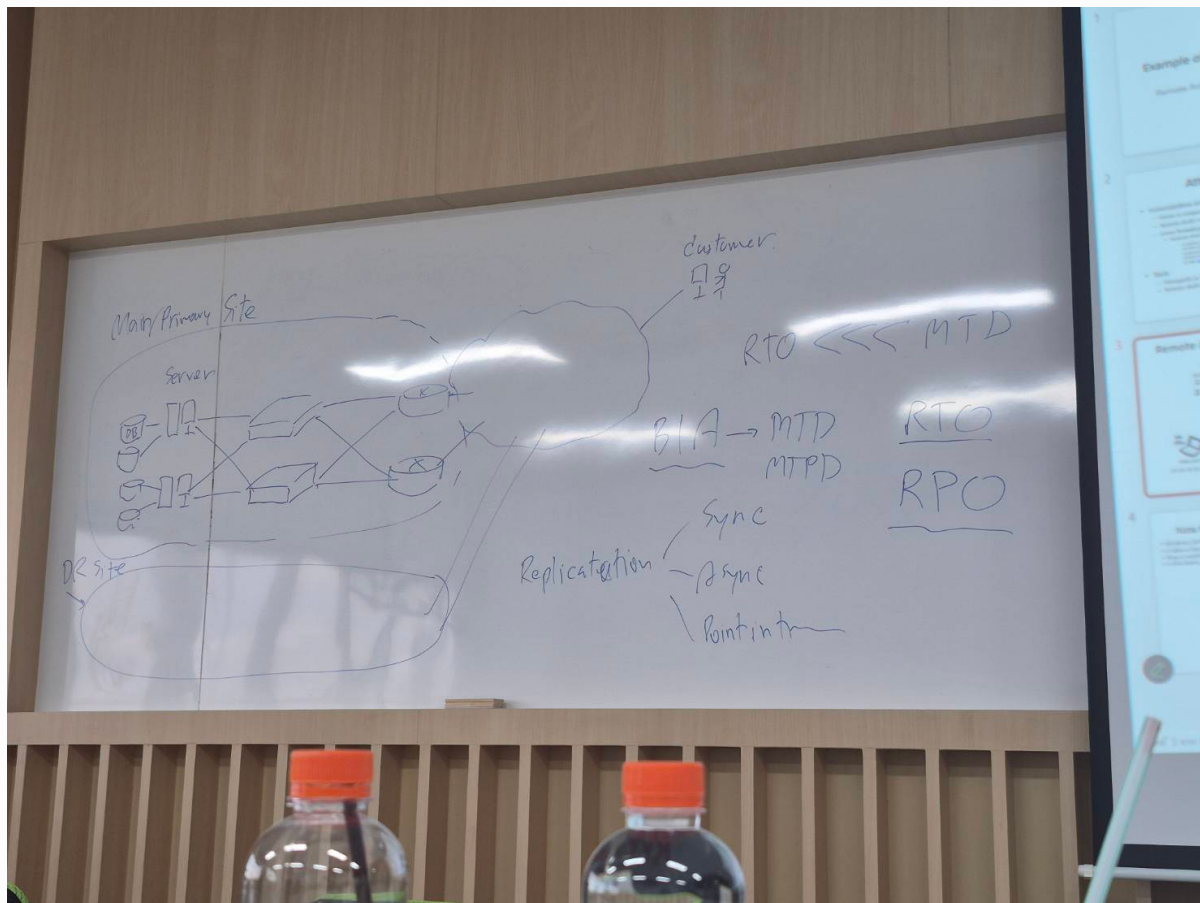
Outbound → ทั่วไปทั่วไป ไว้วางน Trust Zone

↳ มี Reverse shell

b. redirect traffic b) sand box เมื่อมีข้อผิดพลาด, ดูพฤติกรรม

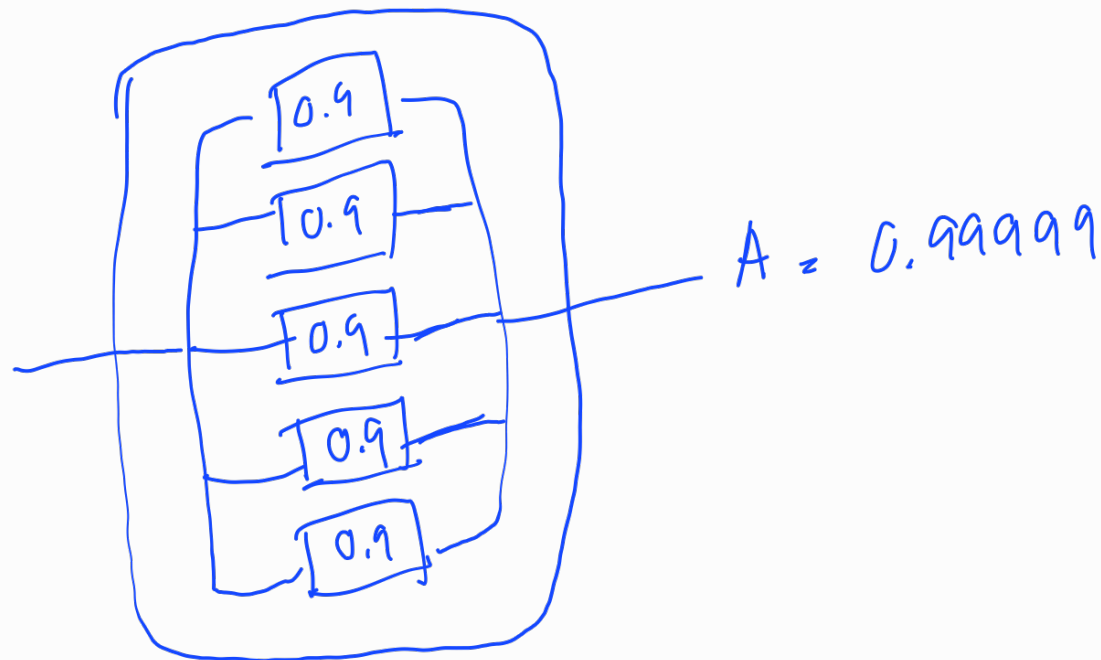
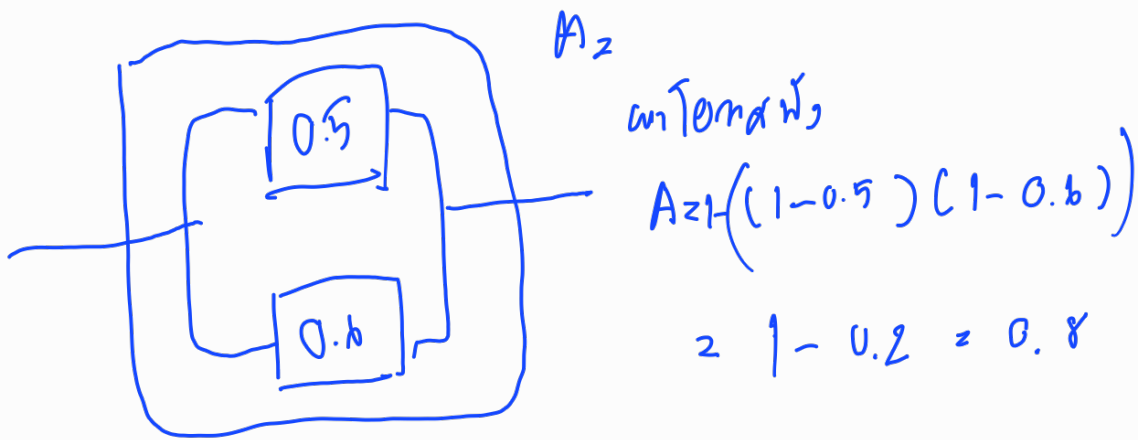
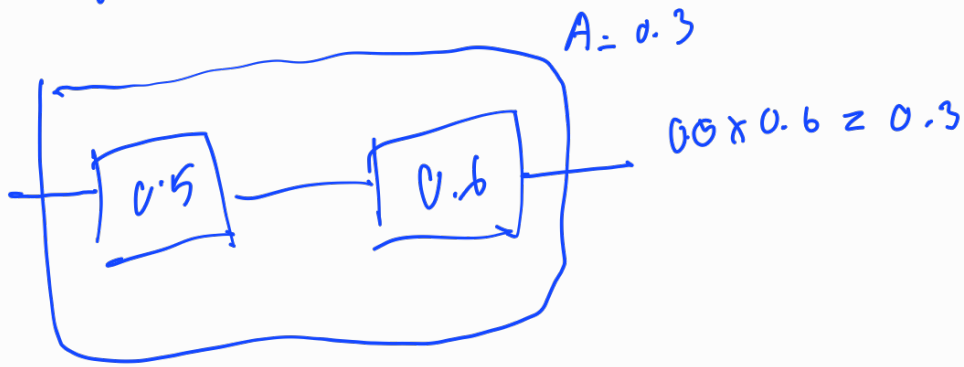
- static

-



ACE? reverse shell

HA? 6010722014: 12021 & 114



10 Thing

🔗 Lockheed Martin

Cyber kill Chain → แบบจำลองการบุกรุกบนเครื่อง

ถ้าตรงกับ phase ใดได้ → Hacker จะใช้ความสามารถที่ตนมีเพื่อทำการโจมตีได้

1. Reconnaissance ^{สอดแนม 👁} { Active → Need สืบค้นกับเครือข่ายของทาง มีการเชื่อมต่อ
Passive → No need สอดแนมแบบไม่ใช้เครื่องมือ Internet Ex. port 0:155555 IP

2. Weaponization ^{อาวุธ} Ex. Malware

ใช้ Tools ต่างๆ

Phishing

Vulnerable Application or Servers

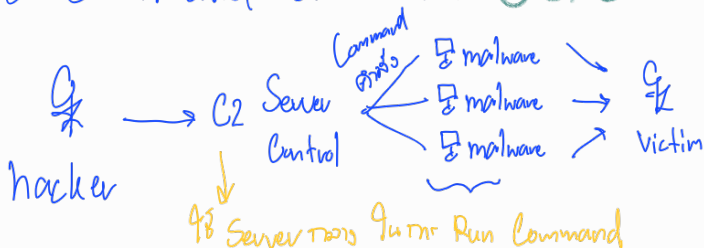
Insider Threats

3. Delivery ^{การส่งมอบ} → การส่งมัลแวร์ไปยังเหยื่อ Ex.  Email Attachments
• malicious link (Link อันตราย)
• USB drive

4. Exploitation ^{การเปิดโอกาส} → การเข้ายึดครองเครื่อง

5. Installation → ติดตั้ง Backdoor บนเครื่องแล้วจะได้เข้าเครื่องวันนั้น

6. Command & Control C&C → C2 Server



7. Actions and Objective Hacker จะทำอะไรต่อ
↳ ทำตามวัตถุประสงค์

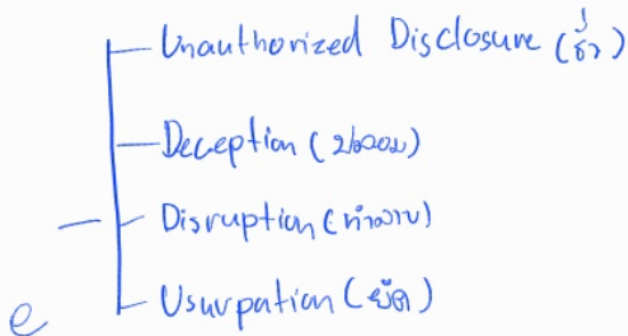
💡 อธิบายแนวคิด Cyber Kill Chain (Lockheed Martin Model) มี 7 ขั้นตอน:

1. Reconnaissance - สืบหาข้อมูลเป้าหมาย
2. Weaponization - สร้างเครื่องมือหรือมัลแวร์
3. Delivery - ส่งมัลแวร์ไปยังเป้าหมาย
4. Exploitation - ใช้ช่องโหว่เพื่อเข้าควบคุมระบบ
5. Installation - ติดตั้ง backdoor/web shell เพื่อเข้าถึงซ้ำได้
6. Command & Control (C2) - เปิดช่องทางสื่อสารสองทางกับเซิร์ฟเวอร์ผู้โจมตี
7. Actions on Objectives - ทำตามเป้าหมาย เช่น ขโมยข้อมูล

Threat RFC 2828

2

Quiz 4:



✔ สรุปตาราง Threat Consequences (RFC 2828)

กลุ่ม Threat Consequence	ลักษณะเฉพาะ	ผลกระทบต่อ Security	ตัวอย่าง Threat Actions
Unauthorized Disclosure	เปิดเผยข้อมูลลับ	Confidentiality	Exposure, Interception, Inference, Intrusion
Deception spoofing	หลอกลวง/ข้อมูลปลอม	Integrity, Authenticity	Masquerade, Falsification, Repudiation
Disruption	รบกวน/หยุดชะงักการทำงาน	Availability	Incapacitation, Corruption, Obstruction
Usurpation Elevation of Privilege	ยึดสิทธิ์/เข้าควบคุมระบบ	Integrity + Availability	Misappropriation, Misuse

13

Practice #4

Digital signature using SHA-256 and RSA encryption

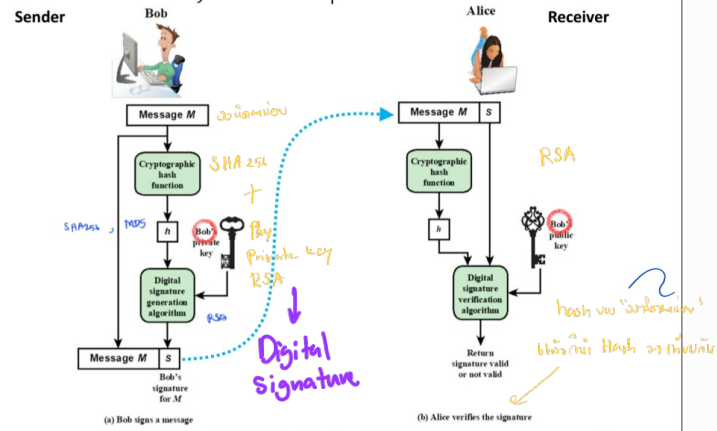
06017467 Information and Cyber Security

16/08/2568

By Sumet Prabhavat, IT/KMITL

2.10.00

System Components



Practice #4 Digital Signature

- Access to the following lab-sheet link
https://docs.google.com/spreadsheets/d/186Xdk9_MjUuNEpdxp1OZ06V27xvUfDdM116LXo/edit?gid=421777627#gid=421777627

Sender side

- Generate message m → 1. write down m to the lab sheet
- Generate keys
 - A pair of keys: public key and private key → 2. write down public key
- Calculate hash of message m using SHA-256
- Encrypt hash of message m to a ciphertext using RSA → 3. write down the signed hash of m

ข้อความ, Public, Cipher (Hashed)

Receiver side

- Calculate hash of message m using SHA-256 → 4. write down the calculated hash of m
- Decrypt the received encrypted hash using RSA → 5. write down the decrypted hash of m

Hash

Cipher

Hash

Notes

Quali

Risk = Prob x Impact

ALE = ARO x SLE

0.1-0.2

Risk Treatment

Avoidance

Risk Mit

Risk Transfer

Risk Acceptance

4. Digital Signature

- ใช้เพื่อ ยืนยันตัวตน (Authentication) และ ความถูกต้องของข้อมูล (Integrity)

ขั้นตอน:

- ผู้ส่งสร้าง Hash ของข้อความ (เช่น SHA256)
- เข้ารหัส Hash ด้วย Private Key ของผู้ส่ง → กลายเป็นลายเซ็นดิจิทัล
- ผู้รับใช้ Public Key ของผู้ส่ง ตรวจสอบว่า Hash ตรงกันหรือไม่
→ หากตรง = ข้อความไม่ได้ถูกแก้ไข และยืนยันได้ว่าเป็นของผู้ส่งจริง

สรุปภาพรวมของทั้งกระบวนการ

ขั้นตอน	เทคโนโลยี	จุดประสงค์หลัก
1	AES	ปกป้องความลับของข้อความ (Confidentiality)
2	RSA	ปกป้องกุญแจลับที่ใช้ใน AES
3	Digital Envelope	รวม AES + RSA เพื่อเข้ารหัสทั้งข้อความและกุญแจ
4	Digital Signature	ยืนยันตัวตนและความถูกต้องของข้อมูล

SHA256

This SHA256 online tool helps you calculate hashes from strings. You can input UTF-8, UTF-16, Hex, Base64, or other encodings. It also supports HMAC.

Settings

Hash

Auto Update

Remember Input

Input Encoding

UTF-8

Output Encoding

Hex (Lower Case)

Enable HMAC

Input

จงนิดหน่อย

Output

9b054674b48d4ac03a1b8f4238c7aabc62c6cdcb0edb58bf18aa2999877e3ed

Select RSA Key Size

1024 bit

Generate RSA Key Pair

Public Key(X.509 Format)

-----BEGIN PUBLIC KEY-----
MIGfMA0GCQsQSB3DQEBAQUAA4GNADCBiQKBgQDVITWLGqoM35AnWx3i4ZWGrNkh1SctqMqEtRowvQ7kms00bMUu9N4cj1+hykpg8afMA4LS04f6zPLRYLqGPNdvor+zvA01uHEOfog7uZcR3FmkMILeHJDjIDPttNdtBvvtFx7xLX7t831bbOpz75EaVLYmhUyKs4guU6qf+QIDAQAB
-----END PUBLIC KEY-----

Download Public Key

RSA Encryption and Decryption

Below is the form to take the inputs for the encryption and decryption. By default, the public/private keys are prepopulated with the keys generated above. You can also supply your own public/private key pairs.

RSA Encryption

Enter Plain Text to Encrypt

9b054674b48d4ac03a1b8f4238c7aabc62c6cdcb0edb58bf18aa2999877e3ed

Enter Public/Private key

BTqp/5AgMBAAECgYAq6YyFZMmpvCLOCr/J324gb7x80ySczGeMamjAuUbdne4Myutbv3Y741oXpDFXCjVHun8HyJuXfUTawa4g20yRP48pbJZGam8NMveun/etqwnvfAc+BmAkcVZ041cA4TP5egf6qZDykpiJHTWTwJ+B23hvy4Qt/2WuiagpgLFOJBAQuCUYDuRFGl86RKRGRxQ4KaPUQHYJwVf2QZf39l9LLYSQE70Xr10ewO+Sk3h0yiGK5ylzCf9+7le9NKi0CQQDnkt062rwwg15pWxVYqgx7cCPLuJBktLkBlxIOV4ym/phvU+Go32GuwMlyRgyfHTI9BJLZmkIK57KGEZf7vH9AKeAk6+QhztTKjT1g+XfNDiEJqN/K6DKFOAEd1lwHXNTRye720IKJ9USDH6zkmM3tyWjNyBSdfEIT60suSleZEoQJAUg3xEeWrv4GNFJvXpoeqxpPeE0dfqri0Gal+3hwtJ3xQrd706qQDZgpag4ILDNp+qGVpxCpUaQNX1Kc0NgKQJAM9OMR9vQ7xFOtDAT39RT70xQerz+SbR5FSnzqQwEAFmuVZKmkMCCQGQuTTIKZFZOWbdd9QJwcyT6A4RhcS2A==

RSA Key Type: ☐ Public key ☒ Private Key

Select Encryption Algorithm

RSA

Encrypt

Encrypted Output (Base64):
k/zMJJPjPKGXiIEodJ+EOeq6q/JYJd38XA1M48fWYh4GJ5rPiNIMMowV3efcV1lyuwCd/4PU2NdVheNNK0cv2Gfa3GoWb4oKidaszdJtMsVTeJly+ON6DvA0SCFDhRfRo8tITZPa+en8tCTZ+KX0KfW2CGDqJoFr7qybM63yss=

RSA Decryption

Enter Encrypted Text to Decrypt (Base64)

SH66Gg8MHB/uTUIZjVHD0Sa1yhAFBAn8D00mw6uEeyTi6kQ6l78mrpeli0hcX6+STzG5oVxbmhyq0Ljy0oeEIDfB79+AtD/113smX1Gh85vqZUNmFuTE+B9UJ4JM30OVbzqazotyRmUCnL8bJD6S/xpswxmSSupLTIHE=

Enter Public/Private key

MIGfMA0GCQsQSB3DQEBAQUAA4GNADCBiQKBgQCCaU5VZpcOm7rPFQzCqQCIFxl/xJDk2EPYzjT0LDY5N2gmHwL5rSFNQd5vBqohvZxZsNZfr3mvgH/WXj3zEo782G+KoufirEdx4Duu30kMsJBMmknfS++Moh4/2ybJhqwfwuw4FXMdm8JppmVProSheH7bWj8oStgmvanEiwiDAQAB

RSA Key Type: ☒ Public key ☐ Private Key

Select Decryption Algorithm

RSA

Decrypt

Decrypted Output:
9b054674b48d4ac03a1b8f4238c7aabc62c6cdcb0edb58bf18aa2999877e3ed

ชื่อ	คำอธิบาย (แปลไทย)
Adware	ซอฟต์แวร์โฆษณาที่ฝังอยู่ในโปรแกรมอื่น อาจทำให้เกิดป๊อปอัพหรือเปลี่ยนเส้นทางเบราว์เซอร์ไปยังเว็บไซต์เชิงพาณิชย์
Attack kit	ชุดเครื่องมือที่ใช้สร้างมัลแวร์ใหม่โดยอัตโนมัติ มีทั้งกลไกการแพร่กระจายและโหลด payload (ส่วนร้ายแรง) ที่หลากหลาย
Auto-rooter	เครื่องมือของแฮกเกอร์ที่ใช้เจาะเข้าสู่เครื่องใหม่ ๆ จากระยะไกลโดยอัตโนมัติ
Backdoor (trapdoor)	กลไกที่หลีกเลี่ยงการตรวจสอบความปลอดภัยปกติ ทำให้สามารถเข้าถึงฟังก์ชันของโปรแกรมหรือระบบที่ถูกบล็อกได้โดยไม่ได้รับอนุญาต <i>Hide Authentication</i>
Downloaders	โค้ดที่ติดตั้งซอฟต์แวร์อันตรายอื่น ๆ ลงในเครื่องที่ถูกโจมตี โดยมักอยู่ในมัลแวร์ตัวแรกเพื่อใช้ดาวน์โหลดมัลแวร์ชุดใหญ่เพิ่มเติม
Drive-by-Download	การโจมตีโดยใช้โค้ดในเว็บไซต์ที่ถูกบล็อกเพื่อใช้ช่องโหว่ของเบราว์เซอร์โจมตีระบบของผู้ที่เข้าเว็บไซต์นั้น
Exploits	โค้ดที่ออกแบบมาเฉพาะเพื่อใช้ประโยชน์จากช่องโหว่หรือชุดของช่องโหว่ในระบบ <i>Special code</i>
Flooders (DoS client)	ใช้สร้างข้อมูลจำนวนมากเพื่อโจมตีระบบเครือข่ายให้ไม่สามารถให้บริการได้ (Denial-of-Service attack) <i>Attacker</i>
Keyloggers	โปรแกรมที่ใช้ดักจับและบันทึกการพิมพ์แป้นพิมพ์บนเครื่องที่ถูกโจมตี <i>Record</i>
Logic bomb	โค้ดที่ถูกฝังอยู่ในโปรแกรมโดยผู้บุกรุก จะทำงานเมื่อมีเงื่อนไขที่กำหนดไว้ เช่น วันที่ หรือเหตุการณ์เฉพาะ เพื่อกระตุ้นการกระทำที่ไม่ได้รับอนุญาต <i>25/12/25</i> <i>ถ้าไม่ไปคอมไพล์ไว้ ตัวจ.ร. ไม่ดี Boot!</i>
Macro virus	ไวรัสที่ใช้มาโครหรือสคริปต์ในเอกสาร เช่น Word หรือ Excel ฝังอยู่ในไฟล์ และจะแพร่เมื่อเปิดหรือแก้ไขเอกสารนั้น
Mobile code	ซอฟต์แวร์ (เช่น สคริปต์หรือมาโคร) ที่สามารถถูกส่งไปยังแพลตฟอร์มต่าง ๆ โดยไม่ต้องปรับแก้และยังคงทำงานได้เหมือนเดิม <i>เปิดโปรแกรมทุก Platform</i>
Rootkit	ชุดเครื่องมือของแฮกเกอร์ที่ใช้หลังจากเจาะระบบเพื่อซ่อนตัวและรักษาสิทธิ์การเข้าถึงระดับ root (ผู้ดูแลระบบ) <i>เพิ่ม Admin ไร</i>
Spammer programs	โปรแกรมที่ใช้ส่งอีเมลขยะ (spam) ปริมาณมาก
Spyware	ซอฟต์แวร์ที่รวบรวมข้อมูลจากเครื่องและส่งต่อไปยังผู้บุกรุก เช่น การบันทึกการพิมพ์ หน้าจอ หรือการจราจรเครือข่าย <i>ไปจอบ</i>
Trojan horse	โปรแกรมที่ดูเหมือนมีประโยชน์ แต่มีโค้ดอันตรายซ่อนอยู่เพื่อ <u>เลี่ยงกลไกความปลอดภัยและมอสิทธิ์</u> ให้ผู้โจมตีเข้าถึงระบบ <i>Hide Code Danger!</i>
Virus	มัลแวร์ที่เมื่อถูกเรียกใช้งานแล้วจะคัดลอกตัวเองไปยังไฟล์อื่น เมื่อไฟล์ที่ติดเชื้อมีถูกเรียกใช้ มัลแวร์ก็จะทำงานต่อไป <i>Copy Paste Paste</i> <i>Copy</i>
Worm	โปรแกรมที่สามารถแพร่ตัวเองได้อัตโนมัติผ่านเครือข่าย โดยอาศัยช่องโหว่ของซอฟต์แวร์ในเครื่องอื่น <i>Vulnerabilities of Software</i>
Zombie, bot	โปรแกรมที่ถูกเปิดใช้งานบนเครื่องที่ติดเชื้อมา เพื่อให้ผู้โจมตีสามารถสั่งให้เครื่องนั้นทำการโจมตีหรือทำงานอื่น ๆ ผ่านเครือข่ายได้

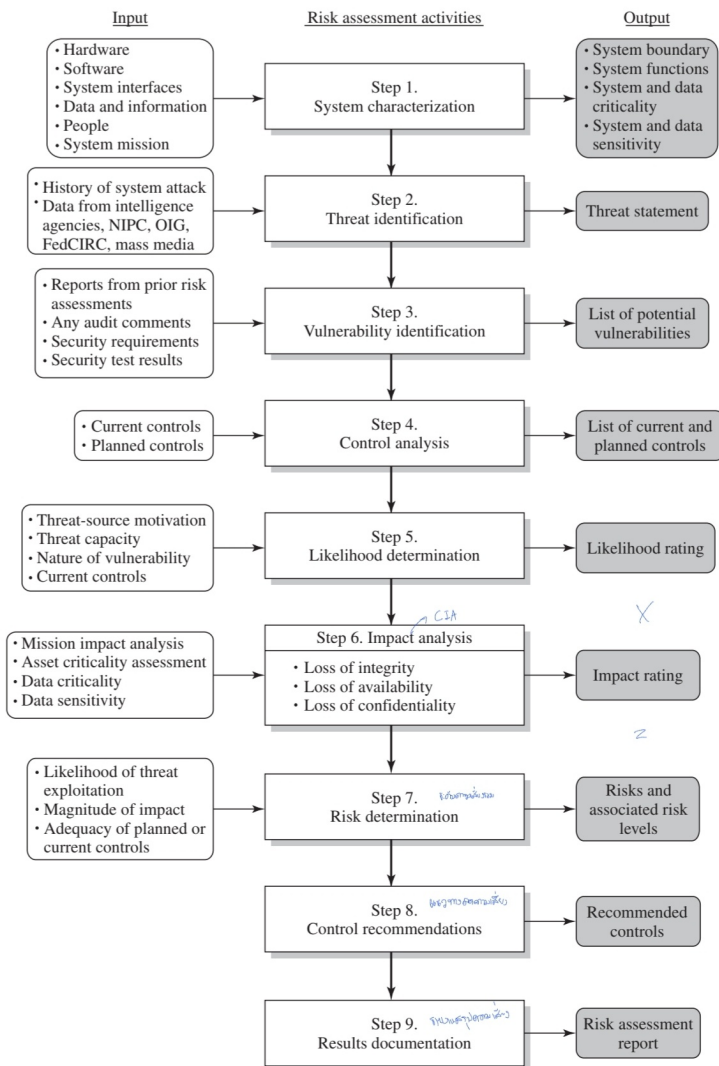


Figure 14.3 Risk Assessment Methodology

Step 8: Control Recommendations (ข้อเสนอแนะการควบคุม)

- **Activity:** เสนอแนวทางจัดการความเสี่ยง เช่น
 - ป้องกัน (Mitigate)
 - โอนความเสี่ยง (Transfer)
 - ยอมรับ (Accept)
 - หลีกเลี่ยง (Avoid)
- **Output:** Recommended controls (มาตรการแนะนำ)

Step 9: Results Documentation (บันทึกผลการประเมิน)

- **Activity:** สรุปผลทั้งหมดเป็นเอกสารรายงาน
- **Output:** Risk assessment report (รายงานผลการประเมินความเสี่ยง)

สรุปภาพรวมแบบสั้น (ง่าย)

ขั้นตอน	ชื่อกระบวนการ	ผลลัพธ์หลัก
1	System Characterization	ระบบและขอบเขตที่ประเมิน
2	Threat Identification	รายการภัยคุกคาม
3	Vulnerability Identification	รายการช่องโหว่
4	Control Analysis	รายการมาตรการควบคุม
5	Likelihood Determination	ระดับความน่าจะเป็น
6	Impact Analysis	ระดับผลกระทบ
7	Risk Determination	ระดับความเสี่ยงรวม
8	Control Recommendations	แนวทางลดความเสี่ยง
9	Results Documentation	รายงานสรุปความเสี่ยง

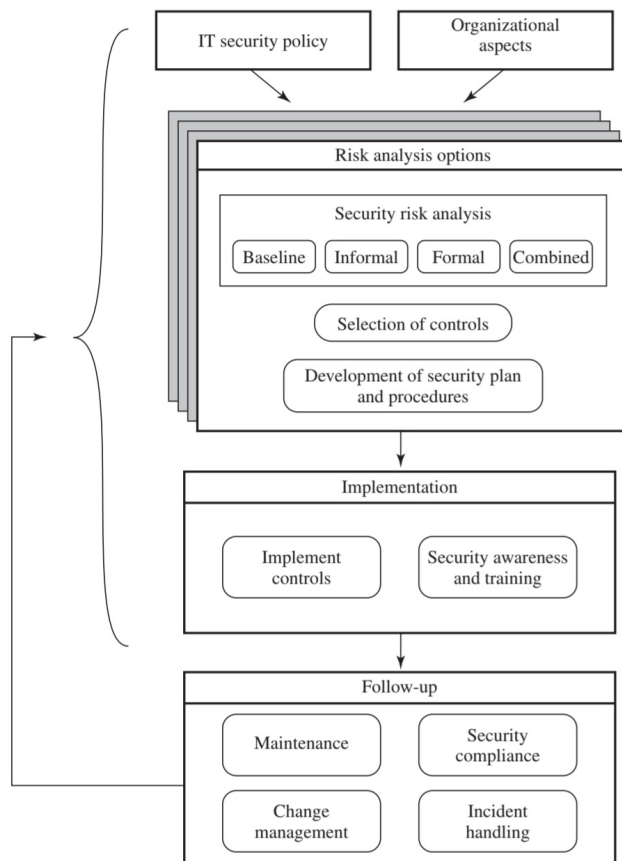


Figure 14.1 Overview of IT Security Management

492/817

470 CHAPTER 14 / IT SECURITY MANAGEMENT AND RISK ASSESSMENT

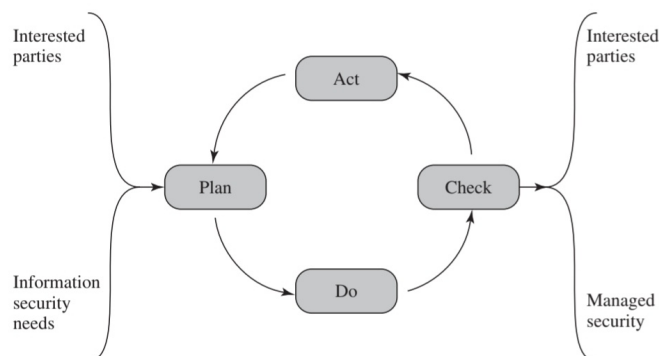


Figure 14.2 The Plan-Do-Check-Act Process Model

วางแผนกำหนดนโยบาย วัตถุประสงค์ กระบวนการ และขั้นตอนด้านความปลอดภัย ประเมินความเสี่ยง พัฒนาแผนการรักษาความเสี่ยง ด้วยการเลือกการควบคุมที่เหมาะสมหรือยอมรับความเสี่ยง

ทำตามแผนการรักษาความเสี่ยง

ตรวจสอบ ตรวจสอบ และรักษาแผนการรักษาความเสี่ยง ◦

ดำเนินการรักษาและปรับปรุงกระบวนการจัดการความเสี่ยงด้านความปลอดภัยของข้อมูลเพื่อตอบสนองต่อเหตุการณ์ ทบทวน หรือระบบการเปลี่ยนแปลง